

ENCUESTA INTEGRAL DE CIBERSEGURIDAD

Kit de Evaluación de Madurez Organizacional - 2026

Versión: 1.0

Fecha: Enero 2026

Clasificación: Información Operacional

Duración Estimada: 45-60 minutos

Público Objetivo: Directores, CISOs, Responsables de Seguridad, Gestores de Vulnerabilidades

INSTRUCCIONES PARA RESPONDIENTES

Esta encuesta evalúa la madurez de ciberseguridad de su organización en **seis áreas críticas**:

1. **Gobernanza y Riesgo (GR)**
2. **Gestión de Vulnerabilidades e EPSS (GV)**
3. **Pruebas de Penetración (PT)**
4. **Monitoreo de Seguridad (SIEM) (SI)**
5. **Respuesta a Incidentes (RI)**
6. **Capacitación y Conciencia de Seguridad (CC)**

Escala de Respuesta: Cada pregunta ofrece 5 opciones (niveles 1-5) donde:

- **Nivel 1:** Inexistente / Ad-hoc / Sin documentación
- **Nivel 2:** Inicial / Parcialmente implementado / Documentación básica
- **Nivel 3:** Definido / Implementado / Documentado y comunicado
- **Nivel 4:** Gestionado / Automatizado / Medido y auditado
- **Nivel 5:** Optimizado / Continuo / Inteligencia artificial y mejora autónoma

SECCIÓN 1: GOBERNANZA Y RIESGO (GR)

GR-01: Política de Gestión de Riesgos Cibernéticos

Pregunta: ¿Existe una política formal de gestión de riesgos cibernéticos alineada con objetivos estratégicos de la organización?

- ☐ Nivel 1: No existe política documentada. Las decisiones de riesgo son reactivas e informales.
- ☐ Nivel 2: Existe política básica, pero su aplicación es inconsistente y no está comunicada a todos los stakeholders.
- ☐ Nivel 3: Política formal documentada, comunicada y aplicada consistentemente en todos los departamentos.
- ☐ Nivel 4: Política integrada en procesos de planificación estratégica con revisión anual y KPIs definidos.
- ☐ Nivel 5: Política adaptativa que evoluciona dinámicamente según cambios de amenazas, con IA para predicción de riesgos emergentes.

GR-02: Marco de Conformidad Regulatoria (NIS2, ENS, GDPR)

Pregunta: ¿Cómo es el estado de implementación de requisitos de marcos normativos aplicables (NIS2, ENS, GDPR, etc.)?

- ☐ Nivel 1: Sin evaluación formal de aplicabilidad normativa. Cumplimiento reactivo ante auditorías externas.
- ☐ Nivel 2: Evaluación inicial de requisitos. Algunos controles implementados, pero con gaps documentados.
- ☐ Nivel 3: Mapeo completo de requisitos. Controles implementados con planes de remediación para gaps.
- ☐ Nivel 4: Cumplimiento demostrable con auditorías internas periódicas y registros de conformidad.
- ☐ Nivel 5: Cumplimiento continuo con monitoreo automatizado, reportes en tiempo real y mejora proactiva de controles.

GR-03: Responsabilidad Directiva y CISO Autonomía

Pregunta: ¿Qué nivel de autoridad y autonomía tiene el CISO/Responsable de Seguridad en decisiones organizacionales?

- ☐ Nivel 1: CISO sin voz en decisiones estratégicas. Reporte a TI con autoridad limitada.
- ☐ Nivel 2: CISO con voz consultiva. Algunas decisiones requieren aprobación de TI/Finanzas.
- ☐ Nivel 3: CISO con autoridad en políticas de seguridad. Reporte directo a dirección ejecutiva.
- ☐ Nivel 4: CISO participa en junta directiva. Define tolerancia al riesgo organizacional junto a CEO/CFO.
- ☐ Nivel 5: Seguridad integrada en decisiones estratégicas de Junta. CISO asesora sobre impacto cibernético de nuevas iniciativas.

GR-04: Gestión de Riesgos de Terceros (Supply Chain Risk)

Pregunta: ¿Cuál es el nivel de formalidad en evaluación y monitoreo de riesgos cibernéticos de proveedores y terceros?

- ☐ Nivel 1: Sin evaluación de riesgos de terceros. Confianza implícita en proveedores.
- ☐ Nivel 2: Evaluación básica mediante cuestionarios. Registro de riesgos sin monitoreo continuo.
- ☐ Nivel 3: Evaluación formal con CAIQ o frameworks estándar. Monitoreo anual o mediante incidentes.
- ☐ Nivel 4: Monitoreo continuo con herramientas especializadas. Auditorías periódicas y SLA de seguridad.
- ☐ Nivel 5: Plataforma de risk intelligence integrada. Monitoreo automatizado con alertas en tiempo real y puntuación dinámica.

SECCIÓN 2: GESTIÓN DE VULNERABILIDADES E IMPLEMENTACIÓN EPSS (GV)

GV-01: Programa de Gestión de Vulnerabilidades Estructura

Pregunta: ¿Existe un programa formal de gestión de vulnerabilidades con procesos, responsabilidades y SLAs definidos?

- ☐ Nivel 1: Sin programa formal. Escaneos ocasionales realizados por TI sin análisis estructurado.
- ☐ Nivel 2: Programa básico con escaneos mensuales. Responsabilidades informales y SLAs no documentados.
- ☐ Nivel 3: Programa formal con escaneos semanales/bi-semanales, roles definidos, SLAs por severidad.
- ☐ Nivel 4: Programa maduro con escaneos diarios/continuos, automatización de reportes, métricas de remediación.
- ☐ Nivel 5: Programa de "gestión de exposiciones" con escaneo continuo, IA predictiva y remediación automatizada.

GV-02: Cobertura de Escaneo de Vulnerabilidades

Pregunta: ¿Qué porcentaje aproximado del "attack surface" total (activos, aplicaciones, OT, cloud) está cubierto por escaneo de vulnerabilidades?

- ☐ Nivel 1: < 20% (solo infraestructura on-premise tradicional)
- ☐ Nivel 2: 20-40% (infraestructura + algunas aplicaciones web)
- ☐ Nivel 3: 40-70% (infraestructura, aplicaciones, algunos servicios cloud)
- ☐ Nivel 4: 70-90% (infraestructura, aplicaciones, cloud, IaC, containerización)
- ☐ Nivel 5: > 90% + contexto comportamental (usuarios, datos, movimiento lateral simulado)

GV-03: Implementación de EPSS (Exploit Prediction Scoring System)

Pregunta: ¿En qué estado se encuentra la adopción de EPSS como métrica complementaria a CVSS?

- ☐ Nivel 1: No utiliza EPSS. Priorización basada únicamente en CVSS u otros scores estáticos.
- ☐ Nivel 2: Piloto inicial con EPSS. Consulta manual de scores, sin integración en herramientas.
- ☐ Nivel 3: EPSS integrado en herramienta de VM. Utilizado para priorización de remediación. Umbral definido (ej: EPSS $\geq$ 0.50).
- ☐ Nivel 4: EPSS con actualizaciones diarias. Automatización de escalaciones basadas en EPSS + contexto organizacional.
- ☐ Nivel 5: Modelo predictivo personalizado + EPSS. Integración con CTI y comportamiento amenazas por sector/geografía.

GV-04: Priorización Integrada (EPSS + CVSS + KEV + SSVC)

Pregunta: ¿Cómo es el estado de integración de múltiples frameworks de priorización (EPSS, CVSS, KEV, SSVC)?

- ☐ Nivel 1: Un único framework utilizado. Sin triangulación de criterios.
- ☐ Nivel 2: Múltiples frameworks consultados manualmente. Decisiones inconsistentes sobre priorización.
- ☐ Nivel 3: Política documentada que integra frameworks. Matriz decisional clara (ej: IF EPSS $\geq$ 0.50 AND CVSS $\geq$ 7.0 THEN Critical).
- ☐ Nivel 4: Automatización de la matriz decisional en herramientas SOAR/SIEM. Escalación automática según criterios.
- ☐ Nivel 5: Orquestación inteligente con IA que pondera factores dinámicamente según contexto real de amenaza.

GV-05: Mean Time to Remediate (MTTR) - Vulnerabilidades Críticas

Pregunta: ¿Cuál es el MTTR promedio para vulnerabilidades categorizadas como "Críticas" por su organización?

- ☐ Nivel 1: Sin SLA definido. Promedio > 90 días o desconocido.
- ☐ Nivel 2: SLA de 60 días. Cumplimiento irregular (< 60% de casos dentro SLA).
- ☐ Nivel 3: SLA de 30 días. Cumplimiento consistente (80%+ de casos dentro SLA).
- ☐ Nivel 4: SLA de 5-7 días. Cumplimiento > 90% con automatización de patching.
- ☐ Nivel 5: SLA de 24-48 horas. Cumplimiento > 95% con patching automatizado y verificación.

GV-06: Gestión de Parches y Validación de Remediación

Pregunta: ¿Existe validación formal de que las vulnerabilidades remediadas fueron realmente eliminadas?

- ☐ Nivel 1: Sin validación post-remediación. Se asume que los parches resolvieron issues.
- ☐ Nivel 2: Validación manual ocasional mediante re-escaneo. Sin documentación de resultados.
- ☐ Nivel 3: Re-escaneo sistemático post-remediación. Tasa de validación > 80%. Registro de cambios.
- ☐ Nivel 4: Validación automatizada integrada en pipeline CI/CD. Dashboards de vulnerabilidad remediated vs open.
- ☐ Nivel 5: Validación inteligente con IA que detecta vulnerabilidades recurrentes y predice riesgo de regresión.

GV-07: Eficiencia Operacional de Gestión de Vulnerabilidades

Pregunta: ¿Cuántas vulnerabilidades activas (open) típicamente gestiona su organización mensualmente?

- ☐ Nivel 1: > 5.000 (utilizando CVSS alto – ruido masivo, equipo abrumado)
- ☐ Nivel 2: 1.000 - 5.000 (reducción moderada mediante cierto filtrado)
- ☐ Nivel 3: 500 - 1.000 (mediante EPSS $\geq$ 0.088 + CVSS $\geq$ 7.0)
- ☐ Nivel 4: 100 - 500 (mediante priorización sofisticada + automatización)
- ☐ Nivel 5: < 100 (gestión de exposiciones predictiva con IA)

SECCIÓN 3: PRUEBAS DE PENETRACIÓN (PT)

PT-01: Programa de Pruebas de Penetración - Cadencia

Pregunta: ¿Cuál es la frecuencia de ejecución de pruebas de penetración (red, aplicaciones, físico)?

- ☐ Nivel 1: Sin pruebas formales o < 1 vez cada 2 años. Pruebas reactivas ante incidentes.
- ☐ Nivel 2: 1 vez por año. Scope limitado a infraestructura on-premise.
- ☐ Nivel 3: 2 veces por año. Scope incluye redes, aplicaciones y endpoints.
- ☐ Nivel 4: Trimestral mínimo. Scope incluye cloud, IoT, supply chain. Metodología documentada (PTES, OWASP).
- ☐ Nivel 5: Continuo con red team. Pruebas simulan adversarios persistentes (APT simulation).

PT-02: Cobertura de Superficies de Ataque

Pregunta: ¿Qué porcentaje del "attack surface" está cubierto por pruebas de penetración?

- ☐ Nivel 1: < 20% (solo datacenter principal)
- ☐ Nivel 2: 20-40% (infraestructura + aplicaciones principales)
- ☐ Nivel 3: 40-70% (infraestructura, aplicaciones, endpoints)
- ☐ Nivel 4: 70-90% (infraestructura, cloud, IoT, físico, social engineering)
- ☐ Nivel 5: > 90% + contexto de cadena de suministro y simulación de campañas dirigidas

PT-03: Metodología y Documentación de Pruebas

Pregunta: ¿Cómo está documentada y estandarizada la metodología de penetration testing?

- ☐ Nivel 1: Sin documentación. Metodología ad-hoc por equipo externo.
- ☐ Nivel 2: Metodología básica documentada. Poca consistencia entre pruebas.
- ☐ Nivel 3: Metodología formal documentada (PTES, OWASP WSTG). Checklist estándar.
- ☐ Nivel 4: Metodología estandarizada con herramientas automatizadas. Evidencia técnica reproducible.
- ☐ Nivel 5: Metodología adaptativa con IA. Automatización inteligente que se ajusta según hallazgos previos.

PT-04: Hallazgos y Métricas de Validez

Pregunta: ¿Qué tasa de hallazgos "válidos" (confirmados, reproducibles, no falsos positivos) típicamente reporta?

- ☐ Nivel 1: Desconocido. Sin validación de hallazgos. Tasa potencial de falsos positivos > 40%.
- ☐ Nivel 2: 60-70% válidos. Validación manual ocasional.
- ☐ Nivel 3: 75-85% válidos. Validación documentada. Falsos positivos identificados y descartados.
- ☐ Nivel 4: 85-95% válidos. Proceso de validación formal integrado. CVSS asignado consistentemente.
- ☐ Nivel 5: > 95% válidos. Hallazgos priorizados por EPSS. Correlación con CTI para contexto real de amenaza.

PT-05: Remediación Post-Pruebas de Penetración

Pregunta: ¿Cuál es el promedio de tiempo para remediar hallazgos críticos de pen testing?

- ☐ Nivel 1: Sin SLA. Promedio > 180 días o desconocido.
- ☐ Nivel 2: SLA de 90 días. Cumplimiento < 50%.
- ☐ Nivel 3: SLA de 30-60 días. Cumplimiento 70-80%.
- ☐ Nivel 4: SLA de 14-30 días. Cumplimiento > 85%. Automatización de remediation scripting.
- ☐ Nivel 5: SLA de 7 días. Cumplimiento > 95%. Remediación integrada en sprint de desarrollo.

PT-06: Re-pruebas de Validación (Remediation Verification)

Pregunta: ¿Se realizan re-pruebas formales para confirmar que los hallazgos fueron realmente remediados?

- ☐ Nivel 1: Sin re-pruebas. Se confía en confirmación del equipo de desarrollo.
- ☐ Nivel 2: Re-pruebas ocasionales para hallazgos críticos únicamente.
- ☐ Nivel 3: Re-pruebas formales para 70%+ de hallazgos críticos y altos.
- ☐ Nivel 4: Re-pruebas para 90%+ de hallazgos. Automatización de validación mediante herramientas.
- ☐ Nivel 5: Re-pruebas continuas + regression testing automatizado. Cierre de hallazgos basado en criterios técnicos validados.

SECCIÓN 4: MONITOREO DE SEGURIDAD (SIEM) (SI)

SI-01: Implementación y Cobertura de SIEM

Pregunta: ¿Existe un SIEM (Security Information and Event Management) centralizado que recopila logs de seguridad?

- ☐ Nivel 1: Sin SIEM. Logs dispersos en sistemas individuales. Sin visibilidad centralizada.
- ☐ Nivel 2: SIEM básico. Cobertura < 30% de infraestructura (solo servidores críticos).
- ☐ Nivel 3: SIEM con cobertura 30-70% (infraestructura, endpoints, aplicaciones). Retención > 90 días.
- ☐ Nivel 4: SIEM con cobertura 70-90%. Integración con herramientas de terceros (firewalls, IDS, endpoint agents).
- ☐ Nivel 5: SIEM avanzado con cobertura > 90%. Integración de cloud, IoT, datos de comportamiento usuario.

SI-02: Capacidad de Detección (Detection Rules)

Pregunta: ¿Cuántas reglas de detección (detection rules) están activas en el SIEM?

- ☐ Nivel 1: < 50 reglas. Detección muy limitada, principalmente basada en threshold simples.
- ☐ Nivel 2: 50-200 reglas. Detección de amenazas comunes. Sin revisión periódica.
- ☐ Nivel 3: 200-500 reglas. Detección de MITRE ATT&CK tactics. Revisión anual.
- ☐ Nivel 4: 500-1.000+ reglas. Correlación multi-evento. Revisión trimestral con mejora basada en telemetría.
- ☐ Nivel 5: 1.000+ reglas + ML-based detection. Rules adaptativas que evolucionan según amenazas emergentes.

SI-03: Mean Time to Detect (MTTD)

Pregunta: ¿Cuál es el MTTD promedio (tiempo desde que ocurre evento malicioso a detección)?

- ☐ Nivel 1: Desconocido o > 30 días. La mayoría de incidentes descubiertos por terceros.
- ☐ Nivel 2: 7-30 días. Detección principalmente manual o mediante alertas genéricas.
- ☐ Nivel 3: 1-7 días. Alertas configuradas para amenazas comunes.
- ☐ Nivel 4: 4-24 horas. Automatización de alertas y correlación de eventos.
- ☐ Nivel 5: < 4 horas. Detección predictiva con IA de anomalías comportamentales.

SI-04: Tasa de Falsos Positivos (FP Rate)

Pregunta: ¿Cuál es la tasa aproximada de falsos positivos en alertas del SIEM?

- ☐ Nivel 1: > 80% (equipo abrumado, 9 de 10 alertas son ruido)
- ☐ Nivel 2: 60-80% (ruido masivo, priorización difícil)
- ☐ Nivel 3: 40-60% (significativo ruido, pero manejable)
- ☐ Nivel 4: 20-40% (mediante baseline tuning y machine learning)
- ☐ Nivel 5: < 20% (comportamiento baselined, anomalías reales detectadas)

SI-05: Respuesta Automatizada (SOAR Integration)

Pregunta: ¿Qué porcentaje de incidentes detectados por SIEM pueden ser manejados de forma automatizada?

- ☐ Nivel 1: 0% (sin automatización. Investigación manual 100%)
- ☐ Nivel 2: < 20% (automatización básica: bloqueo IP, disable cuenta)
- ☐ Nivel 3: 20-50% (playbooks automatizados para incidentes comunes)
- ☐ Nivel 4: 50-80% (SOAR integrado con orquestación de herramientas)
- ☐ Nivel 5: > 80% (orquestación inteligente con toma de decisiones contextual)

SI-06: Retención de Logs y Cumplimiento

Pregunta: ¿Cuál es la política de retención de logs en SIEM y cumple con requisitos regulatorios?

- ☐ Nivel 1: < 30 días o desconocido. No alineado con requisitos regulatorios (GDPR, NIS2, etc.)
- ☐ Nivel 2: 30-90 días. Retención parcial alineada con requisitos.
- ☐ Nivel 3: 1 año. Retención alineada con mayoría de requisitos regulatorios.
- ☐ Nivel 4: 1-3 años. Retención con archivado. Búsqueda en histórico disponible.
- ☐ Nivel 5: Retención ajustable por tipo de log. Cumplimiento automático de requisitos por categoría de datos.

SECCIÓN 5: RESPUESTA A INCIDENTES (RI)

RI-01: Plan de Respuesta a Incidentes

Pregunta: ¿Existe un plan formal de respuesta a incidentes documentado, comunicado y testeado?

- ☐ Nivel 1: Sin plan documentado. Respuesta ad-hoc. Roles no definidos.
- ☐ Nivel 2: Plan básico documentado. Comunicación limitada. Sin pruebas regulares.
- ☐ Nivel 3: Plan formal documentado, comunicado a stakeholders clave. Testeado anualmente mediante tabletop.
- ☐ Nivel 4: Plan con versiones por tipo de incidente. Ejercicios de simulación semestrales. Métricas de respuesta (MTTE, MTTR).
- ☐ Nivel 5: Plan adaptativo. Simulaciones continuas de escenarios realistas. Automatización de triage y escalación.

RI-02: Roles y Responsabilidades en IR

Pregunta: ¿Están claramente definidos los roles y responsabilidades del equipo de respuesta a incidentes?

- ☐ Nivel 1: Roles informales. Sin documentación de responsabilidades.
- ☐ Nivel 2: Roles básicos definidos (líder, técnico, comunicación). Sin matriz RACI detallada.
- ☐ Nivel 3: Roles documentados con matriz RACI clara. Comunicación de responsabilidades.
- ☐ Nivel 4: Roles con playbooks específicos por tipo de incidente. Rotación de roles documentada.
- ☐ Nivel 5: Roles adaptables con orquestación automática según contexto del incidente.

RI-03: Tiempo de Escalación y Comunicación

Pregunta: ¿Cuál es el procedimiento y tiempo para escalar incidentes a dirección y stakeholders externos (reguladores)?

- ☐ Nivel 1: Sin procedimiento formal. Escalación ad-hoc. Desconocimiento de requisitos de notificación.
- ☐ Nivel 2: Procedimiento básico. Escalación típicamente > 24 horas.
- ☐ Nivel 3: Procedimiento documentado. Escalación 4-8 horas. Notificación a autoridades según requisitos.
- ☐ Nivel 4: Escalación inmediata (< 2 horas) con notificación automática. Compliance con NIS2/GDPR (notificación 24h).
- ☐ Nivel 5: Escalación automática según severidad (< 30 min para críticos). Reportes regulatorios pre-generados.

RI-04: Capacidad de Respuesta 24/7

Pregunta: ¿Existe capacidad de respuesta a incidentes 24/7/365 (incluidos fines de semana y festivos)?

- ☐ Nivel 1: Sin disponibilidad 24/7. Respuesta solo en horas de oficina.
- ☐ Nivel 2: 24/7 on-call básica. Contacto alcanzable, pero tiempo de respuesta variable.
- ☐ Nivel 3: 24/7 on-call formalizada con SLA. Equipo contactable dentro 1 hora.
- ☐ Nivel 4: 24/7 con SOC dedicado o rotaciones. Respuesta inmediata con investigación paralela.
- ☐ Nivel 5: SOC 24/7 con redundancia. Respuesta + investigación + comunicación instantánea.

RI-05: Investigación y Análisis de Incidentes

Pregunta: ¿Cuál es la capacidad de investigación forense de incidentes?

- ☐ Nivel 1: Sin capacidad forense. Recolección de evidencia manual y inconsistente.
- ☐ Nivel 2: Herramientas básicas de forensics. Análisis por expertos externos.
- ☐ Nivel 3: Herramientas estándar de forensics (Velociraptor, osquery). Análisis interno para incidentes comunes.
- ☐ Nivel 4: Plataforma forense integrada. Automatización de recolección y análisis inicial. Cadena de custodia documentada.
- ☐ Nivel 5: Laboratorio forense con IA. Análisis automatizado de IOCs, comportamiento de malware, correlación de campañas.

RI-06: Post-Incidente Review (PIR) y Lecciones Aprendidas

Pregunta: ¿Se realizan revisiones post-incidente formales con documentación de lecciones aprendidas?

- ☐ Nivel 1: Sin PIR formales. Incidentes no documentados.
- ☐ Nivel 2: PIR ocasional para incidentes críticos. Documentación inconsistente.
- ☐ Nivel 3: PIR formal para 80%+ de incidentes. Actas documentadas. Acciones de mejora identificadas.
- ☐ Nivel 4: PIR para 100% de incidentes. Baseline de métricas (MTTE, MTTR). Acciones implementadas y verificadas.
- ☐ Nivel 5: PIR automático con análisis de datos. Identificación de patrones. Retroalimentación a detección y prevención.

SECCIÓN 6: CAPACITACIÓN Y CONCIENCIA DE SEGURIDAD (CC)

CC-01: Programa de Capacitación en Seguridad

Pregunta: ¿Existe un programa formal de capacitación en ciberseguridad para empleados?

- ☐ Nivel 1: Sin programa formal. Capacitación ocasional o inexistente.
- ☐ Nivel 2: Capacitación básica obligatoria anualmente. Contenido genérico. Poca relevancia contexto org.
- ☐ Nivel 3: Capacitación anual temática + módulos por rol. Contenido alineado a amenazas locales.
- ☐ Nivel 4: Capacitación multi-canal: presencial, e-learning, micro-learning. Actualización semestral. Roles de alto riesgo con formación adicional.
- ☐ Nivel 5: Programa adaptativo con IA. Contenido personalizado por rol y riesgo. Gamificación y refuerzo continuo.

CC-02: Tasa de Cumplimiento de Capacitación

Pregunta: ¿Cuál es la tasa de cumplimiento (% empleados que completaron capacitación obligatoria)?

- ☐ Nivel 1: < 50% (bajo compromiso. Incumplimiento disperso)
- ☐ Nivel 2: 50-70% (moderado. Recordatorios necesarios)
- ☐ Nivel 3: 70-85% (bueno. Procesos de recall establecidos)
- ☐ Nivel 4: 85-95% (muy bueno. Automatización de recordatorios)
- ☐ Nivel 5: > 95% (excelente. Integración en onboarding y requisitos periódicos automáticos)

CC-03: Simulaciones de Phishing

Pregunta: ¿Se realizan campañas de simulación de phishing para evaluar vulnerabilidad humana?

- ☐ Nivel 1: Sin simulaciones. Sin línea base de susceptibilidad.
- ☐ Nivel 2: Simulación anual. Tasa de click desconocida o > 20%.
- ☐ Nivel 3: Simulación trimestral. Tasa de click 10-20%. Capacitación remedial para high-click users.
- ☐ Nivel 4: Simulación mensual con campañas temáticas (CEO fraud, BEC, etc.). Tasa de click < 10%. Reporting rate medido.
- ☐ Nivel 5: Simulaciones continuas con IA (envíos predictivos). Modelos de comportamiento individual. Detección de phishing reportado > 30% de mails.

CC-04: Tasa de Reporte de Phishing (Reportable Phishing Rate)

Pregunta: ¿Cuál es el porcentaje de phishing que empleados reportan voluntariamente a seguridad?

- ☐ Nivel 1: < 1% (empleados no reportan. Desconocimiento de procedimiento)
- ☐ Nivel 2: 1-5% (reportes ocasionales de empleados conscientes)
- ☐ Nivel 3: 5-15% (cultura de reporte moderada. Botón de reporte visible)
- ☐ Nivel 4: 15-30% (cultura de reporte establecida. Programas de incentivos)
- ☐ Nivel 5: > 30% (cultura proactiva. Empleados como "sensores" de amenazas. Gamificación de reportes)

CC-05: Capacitación Especializada por Rol de Alto Riesgo

Pregunta: ¿Se ofrece capacitación especializada a roles de alto riesgo (ejecutivos, desarrolladores, administradores, personal financiero)?

- ☐ Nivel 1: Sin capacitación diferenciada. Todos reciben contenido genérico.
- ☐ Nivel 2: Capacitación adicional para algunos roles. Contenido básico, sin profundidad.
- ☐ Nivel 3: Capacitación temática por rol (ej: secure coding para developers). Contenido relevante.
- ☐ Nivel 4: Formación especializada continua por rol. Laboratorios prácticos. Certificación interna.
- ☐ Nivel 5: Formación avanzada con simulaciones inmersivas. Ejercicios red team dirigidos contra roles. Mentoría de seguridad.

CC-06: Efektividad de Capacitación (Medición de Comportamiento)

Pregunta: ¿Cómo se mide si la capacitación realmente cambia comportamientos de riesgo?

- ☐ Nivel 1: Sin medición. Se asume retención solo por completación.
- ☐ Nivel 2: Cuestionarios post-capacitación. Quiz score promedio desconocido.
- ☐ Nivel 3: Pre-test y post-test. Mejora de conocimiento 40-60% documentada.
- ☐ Nivel 4: Métricas conductuales: reducción de phishing clicks, aumento de reportes, cumplimiento de MFA. Correlación documentada.
- ☐ Nivel 5: Análisis predictivo de riesgo individual. Intervenciones personalizadas basadas en scores. ROI cuantificado.

CC-07: Comunicación de Incidentes y Conciencia de Amenazas

Pregunta: ¿Existe un programa regular de comunicación sobre amenazas emergentes y lecciones de incidentes?

- ☐ Nivel 1: Sin comunicación formal. Empleados desconocen amenazas o incidentes.
- ☐ Nivel 2: Comunicación ocasional post-incidente crítico. Newsletter anual sobre seguridad.
- ☐ Nivel 3: Boletín mensual de amenazas. Comunicación inmediata de incidentes significativos. Documentación de lecciones aprendidas.
- ☐ Nivel 4: Comunicación continua mediante múltiples canales (Teams, email, cartelería). Análisis de CTI compartido con empleados.
- ☐ Nivel 5: Comunicación personalizada basada en rol y amenaza relevante. Alertas en tiempo real de campañas dirigidas.

SECCIÓN 7: PREGUNTAS DE VALIDACIÓN Y CONTEXTO

V-01: Contexto Organizacional

¿Cuál es el tamaño de su organización?

- ☐ < 100 empleados (start-up / pequeña empresa)
- ☐ 100 - 500 empleados (pequeña-mediana)
- ☐ 500 - 2.000 empleados (mediana)
- ☐ 2.000 - 10.000 empleados (grande)
- ☐ > 10.000 empleados (enterprise)

V-02: Sector Industrial

¿En qué sector principal opera su organización?

- ☐ Administración Pública / Gobierno
- ☐ Banca / Servicios Financieros
- ☐ Salud / Farmacéutica
- ☐ Energía / Infraestructuras Críticas
- ☐ Tecnología / Telecomunicaciones
- ☐ Comercio Electrónico / Retail
- ☐ Manufactura / Industrial
- ☐ Otro: ____

V-03: Presupuesto de Ciberseguridad

¿Cuál es el presupuesto anual aproximado de ciberseguridad?

- ☐ < €100.000
- ☐ €100.000 - €500.000
- ☐ €500.000 - €1.000.000
- ☐ €1.000.000 - €5.000.000
- ☐ > €5.000.000

V-04: Regulación Aplicable

¿Cuáles de las siguientes regulaciones aplican directamente a su organización? (Seleccionar todas las que apliquen)

- ☐ NIS2 (Directiva de Seguridad de Redes e Información)
- ☐ ENS (Esquema Nacional de Seguridad - España)
- ☐ GDPR (Reglamento General Protección Datos)
- ☐ HIPAA (US Healthcare)
- ☐ PCI DSS (Industria de Tarjetas de Pago)
- ☐ TISAX (Defensa / Aeroespacial)
- ☐ ISO 27001 (Certificación voluntaria)
- ☐ Otra / Múltiples: ____

V-05: Evaluación General de Postura de Seguridad

¿Cuál es su evaluación subjetiva actual de la postura de ciberseguridad general de su organización?

- ☐ Crítica (0-20% madurez): Exposición significativa a riesgos. Urgencia inmediata de mejora.
- ☐ Débil (21-40% madurez): Controles básicos inconsistentes. Vulnerabilidades significativas.
- ☐ Aceptable (41-60% madurez): Controles establecidos, pero gaps evidentes. Mejora necesaria.
- ☐ Buena (61-80% madurez): Programa maduro con fortalezas claras y áreas de mejora identificadas.
- ☐ Excelente (81-100% madurez): Programa de seguridad robusto, proactivo y alineado con estándares internacionales.

FIN DE LA ENCUESTA

Gracias por completar esta evaluación integral de ciberseguridad.

Encuesta desarrollada por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad - Enero 2026

Tiempo total estimado: 45-60 minutos

Próximo paso: Consulte la Guía Metodológica para interpretación de resultados y cálculo de IGM